BTS SIO · OPTION SISR · 1RE ANNÉE · BLOC 3

Thème 2
Fascicule des corrections

Corrigés des ateliers Kali K1 à K5, des exercices d'application, du tableau des menaces, du plan de protection, de l'étude de cas finale et du QCM de synthèse

Corrigés — Séance 1 — Les composants de l'identité numérique

Corrigés de la séance 1

Exercice K1.1. (1) L'enregistrement SPF liste les serveurs autorisés à envoyer du courrier pour le domaine ; `-all` demande de rejeter les autres. (2) La priorité ordonne les serveurs : le plus petit nombre est contacté en premier ; avec un seul MX, la valeur n'a pas d'effet pratique mais reste obligatoire. (3) Les serveurs de noms désignent qui héberge la zone DNS : si ce prestataire est compromis ou indisponible, le domaine l'est aussi.

Exercice K1.2. (4) `NOERROR` : la requête a réussi ; `NXDOMAIN` : le nom n'existe pas. (5) 3600 est le TTL en secondes (1 h) : durée pendant laquelle les résolveurs gardent la réponse en cache ; un TTL long retarde la propagation d'un changement d'adresse. (6) Le serveur `192.168.56.2` (résolveur du laboratoire).

Exercice K1.3. (7) Expiration le 30 novembre 2026 : 38 jours restants au 23 octobre (8 jours d'octobre + 30 jours de novembre) ; à surveiller et à renouveler avant l'échéance. (8) Non : seuls `lab.cybernova.test` et `www.lab.cybernova.test` figurent dans les SAN ; un certificat joker (`*.lab.cybernova.test`) serait nécessaire. (9) L'autorité émettrice est une autorité de laboratoire non reconnue par le système ; acceptable en laboratoire, **inacceptable** sur un site public où les navigateurs afficheraient une alerte.

Cas CyberNova. 1 : le nom de domaine ; 2 : non, pas à lui seul ; 3 : l'usurpation de l'identité de l'organisation ; 4 : inventorier les responsables, sécuriser les accès et activer la MFA.

Corrigés — Séance 2 — Les menaces sur l'identité numérique

Corrigés de la séance 2

K2.1. (1) Domaine d'expéditeur `cyber-nova.fr` différent du domaine officiel ; `Reply-To` sur un troisième domaine ; `Return-Path` et serveur d'envoi sans rapport avec CyberNova ; sujet urgent et menaçant. (2) Le nom de domaine et la marque (nom d'affichage « Service Facturation CyberNova »). (3) Le serveur d'envoi n'est pas autorisé par le domaine (SPF), le message n'est pas signé (DKIM) et il échoue à l'alignement DMARC : l'authenticité n'est pas démontrée. (4) L'empreinte prouve que le fichier n'a pas été modifié depuis le recueil : c'est la base de l'intégrité de la preuve.

K2.2. (5) `paiement-secure.example` : on lit de droite à gauche, le nom `cybernova.fr` n'est qu'un sous-domaine. (6) Le site peut exploiter une faille du navigateur, livrer un logiciel malveillant ou tracer la visite ; l'analyse se fait en environnement isolé.

K2.3. (7) `cyber-nova.fr` (MX actif : peut envoyer et recevoir du courrier, déjà vu dans le message suspect) et `cybernova-support.fr` (même hébergeur et même IP : même infrastructure). Les autres sont du stationnement (« parking ») ou des extensions, risque à surveiller mais moindre. (8) Les deux domaines sont très probablement gérés par la même personne : à regrouper dans le signalement.

K2.4. (9) Un domaine créé quatre jours avant l'attaque correspond au schéma classique : enregistrement récent, utilisation immédiate. (10) L'anonymisation est fréquente et légale ; elle ne prouve rien, mais empêche l'identification directe et impose de passer par le registrar et l'hébergeur.

Tableau des menaces (exemple). Typosquatting : G3 × P4 = 12 ; spoofing : G3 × P4 = 12 ; prise de contrôle du compte officiel : G4 × P2 = 8 ; faux compte LinkedIn : G2 × P3 = 6. Priorité : traiter d'abord le domaine et le spoofing, puis sécuriser le compte officiel.

Corrigés — Séance 3 — Les mesures de protection

Corrigés de la séance 3

K3.1. (1) Une politique DMARC : aucun enregistrement `_dmarc` n'est publié. (2) Le serveur de réception peut vérifier SPF seul, sans instruction de rejet ou de quarantaine : l'usurpation peut aboutir selon la configuration du destinataire. (3) Elle sert uniquement à **vérifier** la signature ; la clé privée, qui permet de signer, reste secrète sur le serveur d'envoi.

K3.2. (4) Les autorités autorisées à émettre des certificats pour le domaine (`issue`), et l'adresse de signalement des incidents (`iodef`). (5) `ad` (authenticated data) : le résolveur a validé les signatures ; `RRSIG` est la signature de l'enregistrement. (6) Non : DNSSEC authentifie les réponses DNS, pas l'honnêteté du propriétaire.

K3.3. (7) Le certificat de `cyber-nova.fr` , émis le 20 octobre 2026 pour un nom que CyberNova n'exploite pas. (8) Non : il prouve que quelqu'un a obtenu un certificat pour un domaine proche, comme n'importe quel site. (9) Une surveillance automatique des journaux de transparence avec alerte sur les noms proches.

K3.4. (10) Pour observer qui envoie du courrier au nom du domaine sans rien bloquer, afin d'identifier d'abord les expéditeurs légitimes. (11) Corriger SPF/DKIM des expéditeurs légitimes manquants, puis passer à `quarantine` avec un pourcentage progressif, puis à `reject` .

Plan de protection (éléments attendus). Priorité 1 : MFA et inventaire des administrateurs des comptes officiels et du registrar (coût faible, effet fort) ; priorité 2 : SPF, DKIM et DMARC en `p=none` puis durcissement ; priorité 3 : surveillance des domaines proches et des certificats, réservation défensive, procédure de contre-vérification des virements. Toute proposition est justifiée par un risque identifié et un bénéfice attendu.

Corrigés — Séance 4 — Atelier Kali : audit d'identité numérique

Corrigés de l'atelier K4

K4.1. (1) `ns1` et `ns2` du même domaine : un seul prestataire, point de dépendance unique. (2) `-all` : bonne pratique. (3) Non : la réponse est vide (0 octet). (4) Oui, limité à l'autorité du laboratoire. (5) Non : aucune clé DNSKEY, `dnsrecon` indique « DNSSEC is not configured ». (6) DMARC absent (élevé), DNSSEC absent (moyen), un seul prestataire DNS (faible à moyen), SPF et CAA conformes (points positifs à mentionner).

K4.2. (7) `cyber-nova.fr` et `cybernova-support.fr` : un MX actif permet d'envoyer et de recevoir du courrier crédible, signal fort d'usage pour du phishing. (8) Non : stationnement, revente ou domaine défensif d'un tiers de bonne foi sont possibles ; il faut des indices d'usage frauduleux. (9) Les documenter (captures, relevés DNS, dates) et calculer des empreintes, car les preuves disparaissent après la suppression du domaine.

K4.3. (10) TLS 1.0 et 1.1. (11) Protocoles dépréciés avec des faiblesses connues ; `AES128-SHA` n'offre pas la confidentialité persistante (pas d'échange de clés éphémère). (12) Expiration le 30 novembre 2026, soit 38 jours restants : seuil d'alerte courant à 30 jours, avec renouvellement automatisé. (13) Sans HSTS, un attaquant peut intercepter le premier accès en HTTP avant la redirection.

K4.4. (14) Oui (301 vers HTTPS). (15) HSTS, Content-Security-Policy, X-Frame-Options, Referrer-Policy, Permissions-Policy ; seul `x-content-type-options` est présent. (16) HSTS impose au navigateur d'utiliser HTTPS pour ce domaine pendant une durée donnée, ce qui supprime la fenêtre d'interception.

K4.5. (17) `vpn-test.lab.cybernova.test` : nom évocateur d'un service de test peut-être oublié et exposé ; à vérifier avec le propriétaire du laboratoire avant toute conclusion. (18) Elles identifient directement des personnes : à limiter, protéger et supprimer. (19) Constat : sous-domaine non documenté visible dans les journaux de transparence ; risque : service de test exposé ; recommandation : inventorier, vérifier la nécessité, supprimer ou protéger.

Corrigés — Séance 5 — Procédures de réaction et synthèse

Corrigés de la séance 5

K5.1. (1) Pour empêcher toute modification accidentelle : l'original reste intact et on travaille sur des copies. (2) À adresser le signalement à la bonne équipe de l'hébergeur, qui peut suspendre le serveur. (3) Le SPF n'autorise que l'adresse `203.0.113.77` : la même infrastructure sert à l'envoi des messages et à l'hébergement, ce qui relie le site et les e-mails.

K5.2. (4) Les en-têtes prouvent la réponse du serveur à une date précise (statut, serveur, date) et complètent la capture. (5) Une page de connexion qui imite l'espace client officiel et collecte un mot de passe confirme l'intention de collecte d'identifiants (hameçonnage) : à qualifier comme tel, sans conclure sur l'identité de l'auteur.

K5.3. (6) À contrôler que les fichiers n'ont pas changé depuis le calcul des empreintes. (7) L'empreinte ne correspondrait plus : la commande indiquerait `FAILED` pour ce fichier, la preuve perdrait sa valeur. (8) Pour prouver l'intégrité de l'ensemble transmis, en plus de chaque fichier.

K5.4. Éléments attendus : plaignant et droits (marque, domaine officiel) ; faits datés (domaine créé le 19 octobre 2026, page imitant l'espace client, collecte d'identifiants) ; pièces jointes listées avec empreintes ; demande de suspension et de conservation des données d'enregistrement ; contact. Ton factuel et sans accusation nominative.

Étude de cas. 1 : nom de domaine (faux domaine), comptes officiels et marque (faux compte), e-réputation (accusations publiques). 2 : technique (typosquatting, faux site de collecte), réputationnelle (faux compte, messages accusateurs), juridique (usurpation, éventuelle diffamation ou dénigrement selon le contenu). 3 : clients (vol d'identifiants, fraude, hameçonnage ultérieur) ; entreprise (perte de confiance, coûts de remédiation, obligations RGPD, risque contentieux). 4 : captures datées, URL, messages originaux avec en-têtes, relevés DNS et d'enregistrement, empreintes SHA-256, journal des actions. 5 : immédiat = confinement, préservation des preuves, signalement (registrar, hébergeur, plateforme), information des clients, analyse RGPD avec le DPO ; préventif = MFA, SPF/DKIM/DMARC, surveillance de marque, réservation défensive, sensibilisation. 6 : priorité aux personnes déjà exposées, puis à la coupure de la source (retrait du faux site), puis aux mesures durables, justifiée par la criticité (gravité × probabilité) et le coût.

Corrigés — Annexes

Corrigé du QCM

1-b ; 2-c ; 3-b ; 4-a ; 5-b ; 6-a ; 7-c ; 8-b ; 9-b ; 10-b ; 11-a ; 12-b.